

QuickMed

Pharmacy Portal — Technical Documentation

Project Type:

Web-Based Medicine Ordering System (PHP + MySQL)

Technology Stack:

PHP 8, MySQL, HTML5, CSS3, Vanilla JavaScript

Version:

1.0

Year:

2025

Abstract

QuickMed is a full-stack web application built to streamline the process of ordering medicines online from local pharmacy stores. The system allows customers to register, browse available medicines across multiple shops, add items to a cart, upload prescriptions for Rx-required medicines, and place orders — all from a single browser interface.

On the administrative side, a secure admin panel lets pharmacy staff manage shops, maintain medicine catalogs, approve or reject prescriptions, update order statuses, and view customer feedback.

The application is built using PHP for server-side logic, MySQL for data storage, and plain HTML/CSS/JavaScript for the frontend. It runs on a standard LAMP/XAMPP stack and is designed to be simple enough for small pharmacy businesses to deploy and operate.

Table of Contents

1. Abstract
2. System Overview
3. Project Structure
4. Database Schema
5. Module-wise Description
 - 5.1 User Registration & Login
 - 5.2 Home Page (index.php)
 - 5.3 Place Order
 - 5.4 Prescription Upload
 - 5.5 Order Status
 - 5.6 Contact / Feedback
 - 5.7 Admin Dashboard
 - 5.8 Admin — Manage Shops & Medicines
 - 5.9 Admin — Manage Orders
 - 5.10 Admin — View Prescriptions
 - 5.11 Admin — View Feedback
6. Security Features
7. User Flow Diagrams
8. Key Features Summary
9. Limitations & Future Scope

2. System Overview

QuickMed is designed around two types of users: customers who want to buy medicines, and admins who manage the pharmacy operations. The two sides are completely separated — customers use the main site while admins access a dedicated /admin panel.

2.1 What the System Does

- Customers can register and log in to the site.
- Multiple pharmacy stores can be listed and managed by the admin.
- Each store has its own inventory (medicines + stock quantities).

- Customers select a store, add medicines to their cart, and checkout.
- If any medicine in the cart requires a prescription, the customer must upload one.
- Admins review prescriptions and approve/reject orders accordingly.
- Admins can update order statuses from confirmed to dispatched to delivered.
- Customers can write to support via a contact form; admins can read feedback.

2.2 Technology Stack

Layer	Technology Used
Backend Language	PHP 8 (procedural style)
Database	MySQL (via MySQLi extension)
Frontend	HTML5, CSS3, Vanilla JavaScript
Server Environment	Apache (XAMPP / LAMP stack)
Session Management	PHP native sessions
Password Hashing	PHP password_hash() / password_verify()
File Uploads	PHP move_uploaded_file()
Geocoding	Nominatim OpenStreetMap API (for shop location)

2.3 System Architecture

The application follows a simple multi-page architecture (MPA). Each PHP file handles both the logic (form processing) and the view (HTML output) for its respective page. There is no separate MVC framework — the code is intentionally kept straightforward and easy to read for academic purposes.

Database interactions use prepared statements (MySQLi) to prevent SQL injection. Sessions are used to maintain login state, with additional checks for session hijacking and timeout.

3. Project Structure

The project is organized as follows:

File / Folder	Purpose
index.php	Main customer-facing page — browse medicines, select store, cart
login.php	Customer login with Remember Me feature
register.php	New customer registration with validation
logout.php	Destroys session and clears Remember Me cookie
place_order.php	Handles cart checkout and order creation
order_status.php	Shows customer's order history and tracking
upload_prescription.php	Allows customers to upload prescription files

contact.php	Contact/feedback form for customers
style.css	Main stylesheet for the customer-facing site
script.js	Legacy JS (unused in current version)
includes/db.php	Database connection configuration
includes/session_guard.php	Session validation, timeout, and hijack detection
admin/dashboard.php	Admin home — overview stats and recent orders
admin/login.php	Admin login page
admin/logout.php	Admin session destruction
admin/manage_shops.php	CRUD for shops, inventory, and medicine catalogue
admin/manage_orders.php	View and update all customer orders
admin/view_prescriptions.php	Review and approve/reject prescription uploads
admin/view_feedback.php	Read customer messages from the contact form
uploads/prescriptions/	Directory where uploaded prescription files are saved
uploads/medicines/	Directory for medicine images uploaded by admin

4. Database Schema

The database is named `med_db` and contains the following tables:

4.1 users

Stores registered customer accounts.

Column	Type	Description
id	INT (PK, AUTO)	Unique user ID
full_name	VARCHAR(100)	Customer's full name
email	VARCHAR(150)	Email address (used for login)
phone	VARCHAR(15)	10-digit Indian mobile number (optional)
address	TEXT	Delivery address
password	VARCHAR(255)	Bcrypt hashed password
remember_token	VARCHAR(64)	Hashed token for Remember Me cookie
token_expiry	DATETIME	Expiry time of the remember token

4.2 admins

Stores admin panel credentials.

Column	Type	Description
id	INT (PK, AUTO)	Admin ID
username	VARCHAR(80)	Admin username
password	VARCHAR(255)	Bcrypt hashed password

4.3 shops

Each row represents one pharmacy store.

Column	Type	Description
id	INT (PK, AUTO)	Shop ID
name	VARCHAR(150)	Shop name
address	TEXT	Full address including pincode
phone	VARCHAR(20)	Contact number
maps_link	VARCHAR(500)	Optional Google Maps URL
lat	DECIMAL(10,7)	Latitude (auto-filled via geocoding)
lng	DECIMAL(10,7)	Longitude (auto-filled via geocoding)
is_active	TINYINT(1)	1 = active, 0 = hidden from customers

4.4 medicines

Global medicine catalogue. All shops share this list.

Column	Type	Description
id	INT (PK, AUTO)	Medicine ID
name	VARCHAR(200)	Medicine name
brand	VARCHAR(100)	Brand/manufacturer
price	DECIMAL(10,2)	Default price
stock	INT	Global stock count
requires_prescription	TINYINT(1)	1 = Rx required
image_url	VARCHAR(500)	Path to uploaded image
description	TEXT	Optional description

4.5 shop_medicines

Links medicines to specific shops with per-shop stock. Price uses the medicine's default price.

Column	Type	Description
shop_id	INT (FK)	References shops.id
medicine_id	INT (FK)	References medicines.id
price	DECIMAL(10,2)	Shop-specific price (defaults from medicines table)
stock	INT	Units available at this shop

4.6 orders

Each placed order creates one row here.

Column	Type	Description
id	INT (PK, AUTO)	Order ID
user_id	INT (FK)	Customer who placed the order
shop_id	INT (FK)	Shop from which items are ordered
prescription_id	INT (FK, NULL)	Linked prescription, if required
subtotal	DECIMAL(10,2)	Items total before tax
cgst	DECIMAL(10,2)	Central GST at 6%
sgst	DECIMAL(10,2)	State GST at 6%
delivery_fee	DECIMAL(10,2)	Fixed delivery charge (₹20)

grand_total	DECIMAL(10,2)	Final amount payable
delivery_address	TEXT	Address from user's profile at time of order
status	ENUM	pending / confirmed / rx_pending / dispatched / delivered / cancelled
placed_at	DATETIME	Timestamp of order placement

4.7 order_items

Individual items within each order (snapshot of price at time of ordering).

Column	Type	Description
id	INT (PK, AUTO)	Row ID
order_id	INT (FK)	References orders.id
medicine_id	INT (FK)	References medicines.id
medicine_name	VARCHAR(200)	Name stored at time of order (in case medicine is later edited)
price	DECIMAL(10,2)	Price at time of ordering
qty	INT	Quantity ordered

4.8 prescriptions

Records of uploaded prescription files.

Column	Type	Description
id	INT (PK, AUTO)	Prescription ID
user_id	INT (FK)	Uploader
file_path	VARCHAR(500)	Server path to uploaded file
original_filename	VARCHAR(255)	Original file name for display
status	ENUM	pending / approved / rejected
admin_note	VARCHAR(300)	Admin's review note to patient
uploaded_at	DATETIME	Upload time
reviewed_at	DATETIME	Time of admin review
reviewed_by	INT (FK)	Admin ID who reviewed

4.9 feedback

Customer messages submitted via the contact form.

Column	Type	Description
id	INT (PK, AUTO)	Feedback ID
name	VARCHAR(100)	Sender's name
email	VARCHAR(150)	Sender's email
subject	VARCHAR(100)	Subject category
message	TEXT	Message body
user_id	INT (FK, NULL)	Linked to a user account if logged in
is_read	TINYINT(1)	0 = unread, 1 = read
submitted_at	DATETIME	Submission timestamp

5. Module-wise Description

5.1 User Registration (register.php)

This page lets new customers create an account. It handles both the HTML form display and the POST submission in a single file.

Frontend Validation (JavaScript)

- Name must be 2–60 characters and only letters/spaces
- Email must pass a basic format check
- Phone, if entered, must be a valid 10-digit Indian number starting with 6–9
- Address must be at least 10 characters
- Password must be at least 6 characters; confirmation must match

Backend Validation (PHP)

- All the same rules are re-checked server-side
- Email uniqueness is verified with a SELECT query before inserting
- Password is hashed using password_hash() with PASSWORD_DEFAULT (bcrypt)
- Data is inserted using a prepared statement to prevent SQL injection

5.2 User Login (login.php)

Handles customer authentication with an optional Remember Me feature.

Login Flow

- Email and password are submitted via POST
- Password is verified against the stored bcrypt hash using password_verify()
- On success: session_regenerate_id(true) is called to prevent session fixation
- Session stores: user_id, user_name, login_time, ip_address, user_agent

Remember Me Cookie

- If checked, a cryptographically secure 64-character token is generated using bin2hex(random_bytes(32))

- Only the SHA-256 hash of the token is stored in the database — the raw token goes in the browser cookie
- Cookie is set as HttpOnly to prevent JavaScript from accessing it
- On next visit, the token is looked up, validated against its expiry, and the session is restored
- Each successful auto-login rotates the token (token rolling) to limit theft window

5.3 Home Page (index.php)

This is the main shopping page. It is responsible for displaying the shop selector, medicine grid, and the cart panel.

Shop Selection

- All active shops are fetched from the database and displayed in the sidebar
- When a shop is selected via a GET parameter (?shop_id=N), it is saved to \$_SESSION
- A 'Find Nearest Store' button uses the browser's Geolocation API
- Distances are calculated client-side using the Haversine formula
- The nearest store is auto-selected after location is detected

Medicine Grid

- If a shop is selected, medicines are fetched from shop_medicines JOIN medicines
- If no shop is selected, all medicines from the global catalogue are shown
- Search is supported via a GET parameter ?q= which filters by name or brand
- Stock badges show: 'In Stock', 'Only N left' (≤ 5), or 'Out of Stock' (0)

Cart (JavaScript)

- Cart is maintained entirely in browser memory as a JavaScript array
- Each item stores: id, name, price, qty, requiresRx, and stock limit
- Adding beyond available stock shows an alert and is blocked
- A live invoice shows subtotal, CGST (6%), SGST (6%), delivery (₹20), and grand total
- If any cart item needs a prescription, a warning banner appears

5.4 Place Order (place_order.php)

This is a POST-only handler. It receives the cart as a JSON string and processes the

order.

Validation Steps

- Session check: must be logged in
- Cart array must not be empty and must have ≤ 50 items
- Shop ID must refer to an existing, active shop
- Each cart item must have a valid ID and quantity between 1 and 99
- Each medicine is re-fetched from the database — client-side prices are never trusted

Stock Check

- Before inserting the order, requested quantities are compared against available shop stock
- If any item exceeds stock, an error message is stored in the session and the user is redirected back

Prescription Logic

If any item in the cart has `requires_prescription = 1`, the system checks for an approved prescription:

- Approved prescription found → order status = 'confirmed'
- Only a pending prescription found → order status = 'rx_pending'
- No prescription at all → user is redirected to `upload_prescription.php`

Order Insertion

- Order header inserted into orders table
- Each item inserted into `order_items` (with name and price snapshotted)
- Stock is deducted from both `shop_medicines` and the global medicines table
- All inserts use prepared statements

5.5 Upload Prescription (`upload_prescription.php`)

Lets logged-in customers upload a doctor's prescription file before placing an Rx order.

File Validation

- Allowed types: JPG, PNG, PDF (checked by both MIME type and file extension)
- Maximum file size: 5 MB
- Empty files are rejected

- File is saved with a unique name: rx_{user_id}_{timestamp}.{ext}
- The file path and original filename are saved to the prescriptions table with status = 'pending'

Upload History

- The page also displays the user's last 10 uploads with status badges (Pending / Approved / Rejected) and any admin notes

5.6 Order Status (order_status.php)

Shows a logged-in customer all of their orders with full details.

Features

- Displays shop name, address, and phone for each order
- Shows a 3-step progress bar: Confirmed → Out for Delivery → Delivered
- Cancelled orders skip the progress bar
- Orders with a linked prescription show its status (pending/approved/rejected) with admin notes
- Items can be expanded/collapsed per order to see the full itemized bill
- A 'New order placed' success banner appears when redirected from place_order.php

5.7 Contact / Feedback (contact.php)

A contact form accessible by both logged-in and guest users.

- Logged-in users have their name and email pre-filled
- Subject must be selected from a dropdown (Order Issue, Prescription, etc.)
- Message must be at least 10 characters
- On success, the message is stored in the feedback table
- If the user is logged in, their user_id is also stored for traceability

5.8 Admin Dashboard (admin/dashboard.php)

The admin landing page after login. Shows a quick summary of the system.

- Total registered users
- Total orders placed

- Pending prescription reviews (with a red alert badge in the sidebar)
- Total revenue from non-cancelled orders
- Unread feedback count
- A table of the 5 most recently placed orders

5.9 Admin — Manage Shops & Medicines (admin/manage_shops.php)

This is the most complex admin page, combining shop management and medicine catalogue management in one 3-column layout.

Column 1: Shop Management

- Add a new shop with name, address, phone, and optional Google Maps link
- Address is geocoded automatically using the Nominatim API to extract lat/lng coordinates
- Existing shops can be toggled active/inactive or deleted
- If geocoding failed, a 'Detect' button allows re-running it

Column 2: Shop Inventory

- Selecting a shop shows its current inventory table
- Admin can update stock quantities inline with a 'Save' button
- Medicines can be removed from a shop's inventory
- The 'Add Medicine' tab lets the admin assign any catalogue medicine to the shop with a stock quantity
- Price is always inherited from the catalogue — it is not set per-shop

Column 3: Medicine Catalogue

- Add new medicines with name, brand, default price, stock, Rx flag, image, and description
- Images are uploaded and stored in uploads/medicines/
- Existing medicines can be edited via a modal popup or deleted from the catalogue

5.10 Admin — Manage Orders (admin/manage_orders.php)

A table showing all orders placed by all customers.

- Displays customer name, email, shop name, grand total, prescription status, delivery address, and placement date
- Admin can update any order's status to: Confirmed, Dispatched, Delivered, or

Cancelled

- Status change is a single POST form per row with a dropdown and submit button

5.11 Admin — View Prescriptions (admin/view_prescriptions.php)

Allows admin to review uploaded prescription files.

- Prescriptions are filterable by: Pending, Approved, Rejected, or All
- Image files are shown as thumbnails that open in a lightbox on click
- PDF files are shown as download links
- Admin can enter a note and click Approve or Reject
- On Approve: linked order status changes from rx_pending to confirmed
- On Reject: linked order is cancelled, and the rejection note is shown to the customer
- Reject requires a note — submission is blocked if note is empty

5.12 Admin — View Feedback (admin/view_feedback.php)

Shows messages submitted through the customer contact form.

- Unread messages are highlighted with a green left border
- Stats cards show total unread and total messages
- Filter tabs: Unread only vs All
- Admin can mark messages as read or delete them
- Unread count appears as a red badge on the sidebar link

6. Security Features

The application implements several security measures appropriate for an academic PHP project:

Feature	Where Implemented	How It Works
SQL Injection Prevention	All DB queries	Uses MySQLi prepared statements with bind_param throughout
Password Hashing	register.php, login.php	PHP password_hash() (bcrypt) — plain passwords never stored

XSS Prevention	All output pages	htmlspecialchars() used on all user-supplied data before display
Session Fixation Prevention	login.php	session_regenerate_id(true) called immediately after successful login
Session Timeout	session_guard.php	Sessions expire after 30 minutes of inactivity
Session Hijacking Detection	session_guard.php	IP address is stored at login and checked on every request
Session ID Rotation	session_guard.php	Session ID regenerated every 10 minutes automatically
Secure Remember Me Token	login.php	Raw token in cookie, SHA-256 hash in DB; token is rotated on each use
HttpOnly Cookie	login.php, logout.php	Remember Me cookie has HttpOnly flag — inaccessible from JavaScript
File Upload Validation	upload_prescription.php	Checks MIME type, extension, file size, and UPLOAD_ERR_OK status
Unique Upload Filenames	upload_prescription.php	Files saved as rx_{userid}_{timestamp}.ext to prevent overwriting
Admin Authentication	All admin pages	Check for \$_SESSION['admin_id'] at the top of every admin file
Input Length Caps	register.php, contact.php	maxlength enforced both in HTML and PHP-level validation
Prescription Note Sanitization	view_prescriptions.php	strip_tags() and substr() applied to admin notes before storing
Cart Price Trust	place_order.php	Client prices are ignored; all prices re-fetched from DB at order time
Stock Re-check at Checkout	place_order.php	Stock availability is verified server-side before order is inserted

7. User Flow Diagrams

7.1 Customer Order Flow

Step	Action	System Response
1	Visit site, browse medicines	Medicines shown without login; Add to Cart disabled until store is selected
2	Select a medical store from sidebar	Page reloads with that store's inventory and prices
3	Add medicines to cart	Cart panel opens; live invoice updated
4	Click 'Confirm Order'	If not logged in → prompted to login; if logged in → cart submitted to place_order.php
5a (No Rx needed)	Cart has only OTC medicines	Order inserted directly with status = 'confirmed'

5b (Rx need ed, appro ved)	Cart has Rx medicines; approved prescription exists	Order inserted with status = 'confirmed'
5c (Rx need ed, pendi ng)	Cart has Rx medicines; pending prescription exists	Order inserted with status = 'rx_pending'
5d (Rx need ed, none)	Cart has Rx medicines; no prescription uploaded	Redirected to upload_prescription.php
6	Prescription uploaded	Admin reviews it; order status updated on approval/rejection
7	Admin dispatches order	Status → dispatched; customer sees it on order_status.php
8	Order delivered	Status → delivered

7.2 Admin Prescription Review Flow

Step	Action	Result
1	Customer uploads prescription	Record inserted in DB with status = pending
2	Admin sees pending count badge in sidebar	Navigates to view_prescriptions.php
3	Admin reviews file (image/PDF)	Clicks Approve or Reject with an optional note
4a (Appr ove)	Admin submits approval	Prescription status → approved; linked order → confirmed
4b (Reje ct)	Admin submits rejection with note	Prescription status → rejected; linked order → cancelled
5	Customer views order_status.php	Sees updated status and admin's note

8. Key Features Summary

Feature	Description
Multi-store support	Multiple pharmacy shops can be listed; each has independent inventory
Nearest store finder	Uses browser Geolocation + Haversine formula to rank stores by distance
Live cart with invoice	Cart updates in real time with subtotal, CGST, SGST, delivery, and grand total
Stock-aware cart	Add-to-cart is blocked beyond available stock; max-stock alerts shown inline
Prescription workflow	Rx medicines require an uploaded prescription; admin reviews before order is confirmed

Prescription history	Customers can see all their uploads with status and admin notes
Remember Me login	Secure 30-day cookie with server-side token hashing and automatic rotation
Session security	IP binding, timeout, and periodic ID regeneration to protect sessions
Medicine image uploads	Admin can upload photos for each medicine; stored in uploads/medicines/
Order progress tracking	Visual 3-step progress bar per order: Confirmed → Dispatched → Delivered
Tax-inclusive billing	Orders show a split GST breakdown (CGST + SGST at 6% each)
Admin feedback inbox	Customer messages are stored and viewable with read/unread status
Geocoded shop locations	Shop addresses are auto-geocoded using Nominatim for nearest-store calculations
Responsive search	Medicine search filters by name and brand as you type (Enter to search)
Snapshot pricing	Order items store price and name at time of purchase for accurate history

9. Limitations & Future Scope

9.1 Current Limitations

- No payment gateway integration — orders are placed without any real payment processing
- No email or SMS notification system for order status changes
- Admin panel has no role-based access control — any admin can do everything
- No mobile app; the site is responsive to some extent but not fully optimized for mobile
- Geocoding depends on Nominatim, a free public API with rate limits — may fail under heavy use
- Cart is stored in browser memory only — refreshing the page clears it
- No coupon or discount system
- Medicine search requires pressing Enter; no real-time filtering without page reload
- HTTPS is not enforced by default (should be configured at the server level)
- The Remember Me cookie uses secure: false in development — must be set to true in production

9.2 Future Scope

- Integrate a payment gateway (Razorpay or PayU) for online payment

- Add email notifications using PHPMailer or an SMTP service
- Build a REST API to support a mobile application (Android/iOS)
- Implement role-based admin access (pharmacist, delivery person, superadmin)
- Add real-time order tracking with delivery person location
- Implement a coupon/promo code system
- Add medicine expiry date tracking and automated alerts
- Allow customers to reorder from past orders with a single click
- Add a customer review and rating system for medicines
- Migrate to a PHP framework (Laravel) for better maintainability at scale

— *End of Document* —